INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Submission detail	Entry
Student name	Kelechi Kenneth Nwankwo
Student ID	2025/GCR/12814
Official email	gcr2512814@students.icdfa.edu.ng
Role adopted	Practical, risk-based 12-month security awareness programme
File name	Northbridge Logistics 12-Month Security Awareness Programme.
Submission date	11th November, 2026

Introduction, Scope and Assumptions

Northbridge Logistics does not lack good intentions; it lacks time, people and money. That shapes everything in this report. Rather than a long list of courses, I propose a small number of changes to everyday behaviour, each one practised in the way that suits the person doing the job, and each one measured by what people actually do. The program follows the five-stage lifecycle: assess, plan, deliver, measure and improve.

Scenario facts (from the brief). 800 staff across head office, warehouses and remote sales; recent invoice-fraud attempts; two staff reused passwords after a breach; regulated customer data; a small security team and a modest training budget; leadership wants fewer incidents within 12 months.

My assumptions (proposals, not Northbridge results).

- The security team has about four people. One of them, the Security Awareness Coordinator, can give roughly half their time to this program, supported by HR/Learning and IT Operations.
- The budget is about USD 30,000 for the year, covering a phishing-simulation and micro-learning licence, printed warehouse materials and small recognition items. Training happens in paid working time.
- Northbridge already has an email platform that supports a “Report” button, an identity provider that can enforce multi-factor authentication (MFA), and an HR learning system. Warehouse staff mostly use shared handheld scanners and their own phones rather than daily email.
- Audience sizes are illustrative: finance and procurement 40; head office and leadership 170; warehouse and logistics operations 440; remote sales 100; IT, service desk and HR 50.
- Every target in this report is a **proposed target**, a planning choice and not an existing result.

Task 1: Assess

#	Risk	Why it matters (scenario evidence)	What staff should do instead
R1	Invoice fraud and payment redirection (fake invoices, spoofed suppliers or executives, changed bank details)	The brief reports recent invoice-fraud attempts. One success means a direct and often unrecoverable loss, and the attack works by creating time pressure on a person.	Verify any new invoice, bank-detail change or urgent payment request by calling a known number from the supplier record, never one in the message. Use two-person approval above a set value.
R2	Password reuse and weak credential habits	Two staff reused passwords after a breach, so exposed credentials were being tried against company accounts. With regulated data, one taken-over account can become a reportable incident.	Use a unique passphrase for each work account, keep it in the approved password manager, enrol in MFA, and never use work credentials on personal sites.
R3	Slow or missing reporting of suspicious messages and mistakes (including data-handling errors)	With a small security team, staff are the early-warning system. Regulated data adds time-sensitive duties, so a mistake hidden for days costs far more than one reported in minutes. Reuse of passwords after a breach also suggests earlier incidents did not change habits.	Report anything odd straight away through the one-click button or hotline, including your own mistakes. Reporting is always welcomed and never penalised.

I ranked these by likelihood and impact. R1 has the biggest direct financial impact, R2 is a common way into systems, and R3 is the multiplier: faster reporting reduces the damage from R1, R2 and almost anything else.

Audience segments and their needs

Audience (assumed size)	Work context and access	Needs
Finance and procurement (40)	Handle invoices, supplier records and payments; the group most targeted by fraud.	Realistic fraud scenarios, a simple call-back procedure, confidence to challenge senior requests, and a job aid at the desk.
Head office and leaders (170)	Email-heavy work with access to customer and commercial data; executives are often impersonated.	Short, practical content. Leaders must model the behaviour and openly support no-blame reporting.
Warehouse and operations (440)	Shift work, shared handhelds and little desk time; some staff have limited digital confidence or different first languages. Exposure is mainly texts, shared logins and tailgating.	Very short face-to-face sessions at shift start on every shift (including nights), visual plain-language materials, and a reporting route that does not need email.
Remote sales (100)	Laptops and phones, public Wi-Fi, direct customer contact, customer data in the CRM.	Flexible virtual content, guidance on working with customer data away from the office, and fast help when something looks wrong.
IT, service desk and HR (50)	Reset passwords, issue accounts and hold personal data; targets for impersonation by phone.	Identity-verification rules, role-play practice and clear escalation paths.

Pre-launch baseline (six weeks before launch)

Without a baseline we cannot show change. Before any training begins I would capture the following, and say plainly where records are missing.

Baseline measure	Evidence source
Click and report rates on an unannounced phishing simulation (office and remote), plus a text-message simulation for a sample of warehouse staff	Phishing-simulation platform
Invoice-fraud attempts in the last 12 months, how many reached payment stage, and any losses	Finance records, email security logs, incident register
Share of 30 sampled bank-detail changes with a documented call-back	Accounts payable audit sample
Accounts with reused or breached passwords; MFA coverage; password-reset tickets	Identity provider reports, breached-password check, service desk tickets
Human-error incidents in the last 12 months and the time from event to report	Incident register, ticket timestamps
A five-question confidence and knowledge pulse by audience and shift	Short survey via HR system, QR code in warehouses

If history is incomplete, I would treat the first three months of data as the working baseline and say so in every report.

Task 2: Assess

Three measurable objectives (proposed targets)

Objective	Target and deadline	Evidence	Accountable owner
O1: Safer payments (R1)	By end of Month 6, at least 95% of sampled bank-detail changes and high-value invoices have a documented call-back, sustained to Month 12, with zero fraudulent payments released in the year.	Monthly AP audit sample; finance incident log	Finance Director
O2: Stronger credentials (R2)	By end of Month 9, 100% of accounts with access to regulated data use MFA, at least 90% of office, remote and finance staff use the approved password manager, and reused or breached-password detections fall at least 80% from baseline.	Identity provider and password manager reports	IT Operations Manager
O3: Faster reporting (R3)	Raise the simulation report rate from baseline to at least 30% by Month 6 and 50% by Month 12, and bring the median time to report under 30 minutes by Month 12.	Simulation platform; ticket timestamps	Head of Information Security

Click rate is tracked as a supporting measure, but the report rate is the main behavioural signal because it shows people noticing and acting.

Sponsor and owners

- **Executive sponsor: Chief Operating Officer.** Approves budget and paid training time, signs the no-blame commitment, receives quarterly reports and removes blockers. Most staff work in operations, so this is the right sponsor.
- **Program owner: Head of Information Security.** Accountable for the plan, the metrics and the quarterly review.
- **Security Awareness Coordinator (about 0.5 FTE).** Builds content, runs simulations, supports champions and prepares reports.
- **Finance Director** owns the call-back rule and O1. **IT Operations Manager** delivers MFA, the password manager and the Report button, and owns O2.
- **HR / Learning Manager** runs onboarding, the learning system, attendance records and recognition. **Warehouse Operations Managers and shift supervisors** release staff for toolbox talks and encourage reporting on the floor.
- **Data Protection Officer** advises on regulated data and triages data incidents. **Security Champions** (about 15 volunteers across sites and teams) reinforce messages and pass feedback upward.

Topics by audience, linked to risks

Audience	Core topics	Risks
Finance and procurement	Spotting fake invoices and changed bank details; the call-back procedure; challenging urgent executive requests; two-person approval	R1, R3
Head office and leaders	Phishing and impersonation; password manager and MFA; handling customer data; the leader's role in no-blame reporting	R1, R2, R3
Warehouse and operations	Text-message and QR-code scams; never sharing handheld logins; locking screens; challenging unknown visitors; how to report fast	R2, R3
Remote sales	Public Wi-Fi and personal phones; customer-data handling; unique passwords and MFA; reporting lost devices	R2, R3
IT, service desk and HR	Verifying callers before resets; signs of account takeover; escalating suspected incidents; data-protection duties	R2, R3

Task 3: Assess

Delivery formats and why they fit

Audience	Format	Why it fits
Finance and procurement	45-minute live workshop on fraud scenarios; quarterly 10-minute drills; one-page call-back job aid	Practising on real processes works better than slides, and a small group can rehearse challenging a senior request.
Head office and leaders	Ten-minute micro-modules every two months; 30-minute leader briefing	Fits busy diaries; leaders must be seen backing the behaviours.
Warehouse and operations	Five-minute toolbox talks at shift start on all shifts; picture cards at docks and handheld stations; QR link to a short mobile lesson; main site languages	Mirrors how warehouse teams already get safety briefings and needs no email or desk.
Remote sales	Twenty-minute virtual sessions, short videos, a monthly tip	Flexible and needs no travel.
IT, service desk and HR	Twice-yearly role play with real reset and impersonation scenarios	These roles are attacked through conversation, so practice beats reading.

Every session ends with one action people can do straight away, such as calling the number on file or pressing Report.

Onboarding

New starters complete a 20-minute essentials module in week one. IT sets up their password manager and MFA when the device or account is issued, so the safer action is built in from day one. A short scenario check follows at

week four. Warehouse starters get the same content as a face-to-face induction toolbox talk, including hands-on practice logging in to a handheld.

Phishing simulation approach with supportive follow-up

- **Rhythm:** a baseline simulation before launch, then roughly every six weeks for office, remote, finance and IT groups, with difficulty rising gradually. Warehouse staff get two text-message or QR-code simulations a year, matching their real exposure. One part-time coordinator can sustain this.
- **Realism with fairness:** finance receives invoice themes, IT receives reset requests, and remote staff receive delivery and customer themes. Simulations never use pay, redundancy, bereavement or health as bait.
- **If someone clicks:** a 60-second "teachable moment" page explains the clues and what to do next time. No penalty and no naming in team meetings.
- **If someone reports:** an immediate thank-you confirms the right action.

- **Repeat clickers** (two or more in three months) are offered an optional, confidential 15-minute coaching chat that is not shared with line managers. Managers see team results only for groups of ten or more.

No-blame reporting route

1. **Email users:** a one-click Report button in the mail client sends the message to the security team.
2. **Warehouse staff and anyone without a desk:** a short phone number and QR code on handhelds, posters and badges opens a simple form. Supervisors can also log a report verbally on a colleague's behalf.
3. **Mistakes:** a clearly named "Tell us fast" channel (24/7 mailbox and phone line via the service desk) for clicked links, lost devices, wrong-recipient emails and data errors.
4. **Response:** the reporter gets an acknowledgement within one working hour and feedback on the outcome. Suspected personal-data incidents go straight to the Data Protection Officer.
5. **Commitment:** the COO signs a short no-blame statement shown at induction, on the intranet and on warehouse boards: prompt reporting of an honest mistake will not lead to discipline.

Task 4: Assess

I separate reach (did people get the content), behaviour (did they act more safely) and outcomes (did harmful incidents fall). Completion alone is never treated as success.

Metric	Calculation	Data source	Owner	Review	What a change means
M1 Reach: role-appropriate participation	Staff completing assigned activities ÷ staff assigned, by audience and shift	Learning system; toolbox sign-in sheets	HR / Learning Manager	Monthly	Low warehouse or night-shift reach points to an access problem, not lack of interest.
M2 Behaviour: simulation report rate (and click rate)	Reporters ÷ recipients; clicks ÷ recipients	Simulation platform	Security Awareness Coordinator	Each simulation; reviewed monthly	A rising report rate against baseline shows people noticing and acting. Fewer clicks with a flat report rate may mean people are ignoring threats instead of reporting them.
M3 Behaviour: median time to report	Median minutes from delivery (or incident) to first report	Email logs; ticket timestamps	Head of Information Security	Monthly	Shorter times give attackers less room to do damage.

M4 Behaviour: verified payment changes	Sampled changes and high-value invoices with documented call-back ÷ sample (30 a month)	Accounts payable audit	Finance Director	Monthly	Hitting target shows the safer procedure is part of daily work.
M5 Behaviour: credential hygiene	Accounts flagged for reused or breached passwords; password-manager adoption %; MFA coverage %	Identity provider and password manager reports	IT Operations Manager	Monthly	Fewer flagged accounts and higher adoption show O2 is on track.
M6 Outcome: human-factor incidents	Confirmed human-error incidents per 100 staff, by category; fraud attempts reaching payment stage; losses	Incident register; finance records	Head of Information Security	Quarterly	Fewer incidents that cause harm is the result leadership asked for.

Reading the numbers with care. Total reports and logged incidents may rise in the first months simply because people now report more, which is a good sign. I will therefore track “incidents that caused harm” separately from the volume of reports.

Reporting to leadership

- **Monthly:** a one-page dashboard for the Head of Information Security and the sponsor, showing M1 to M5 against baseline and target with red, amber or green status.
- **Quarterly:** a short executive briefing with three headline numbers (report rate, verified payments, harm-causing incidents), the trend against baseline and a plain statement of progress.
- **Limitations, every time:** small samples in some groups, differences in simulation difficulty, a short baseline, and the difficulty of proving training alone caused a change.
- **Decisions requested:** for example, making the call-back rule mandatory policy, protecting paid time for toolbox talks, extending password-manager licences, or funding translation.

Task 5: Improve and sustain

Quarterly review routine

A 60-minute review runs in Months 3, 6, 9 and 12. **Attendees:** Head of Information Security (chair), Security Awareness Coordinator, HR / Learning Manager, Finance Director or delegate, IT Operations Manager, a warehouse operations manager, the Data Protection Officer and one Security Champion. The sponsor receives the summary and joins the Month 6 and Month 12 reviews. **What they examine:** M1 to M6 against baseline and target, simulation results by audience, an incident and near-miss review, learner feedback themes and open actions. **How actions are recorded:** in a shared action register with owner, due date and status, checked first at the next meeting; anything that misses two reviews in a row goes to the sponsor.

Triggers for updating content between reviews:

- A real incident reaching payment stage or exposing data: a short briefing for affected groups within 10 working days.
- A new scam pattern seen in three or more reports, or an external alert: a bulletin within five working days.
- A process or system change (new supplier portal, new handhelds, new finance workflow): content updated before go-live.
- A metric off track for two reviews in a row: redesign the format and message, not just repeat it.

Listening to learners

Every module and toolbox talk ends with a three-question pulse (was it useful, was it clear, what would you change), with a QR code for warehouse staff so no email is needed. Each quarter the coordinator runs short focus groups of six to eight people per audience, scheduled on every shift including nights, and champions gather informal feedback in between. Results are analysed by role and shift, and changes are fed back through a "You said, we did" notice so people see that speaking up works. Feedback also checks access: language, reading level, time released and device availability.

Recognising good behaviour

1. **"Great Catch" recognition.** People who report a real threat or a useful near-miss are thanked personally and, with permission, highlighted in team briefings, on the intranet or warehouse board. A site-level "Great Catch of the Quarter" award keeps it visible.
2. **"Own It Early" thank-you.** People who promptly report their own mistake receive a personal thank-you from the Head of Information Security, and anonymised "what we learned" stories show that fast reporting limited the damage. Nobody who clicked or made an error is ever named.

Consistency check: risk to review decision

Risk	Audience	Objective	Main activity	Metric	Review decision
R1	Finance; leaders	O1	Fraud workshop, call-back job aid, quarterly drills	M4, M6	Tighten procedure or add drills if sample falls below 95%
R2	All; IT/HR	O2	MFA and password-manager rollout, toolbox talks, service-desk role play	M5, M6	Add rollout support where adoption lags
R3	All	O3	Simulations, Report button and hotline, recognition	M2, M3, M1	Change formats where reach or reporting stays low

Sources

- National Institute of Standards and Technology (NIST). *SP 800-50 Rev. 1: Building a Cybersecurity and Privacy Learning Program* (2024).
- NIST. *SP 800-63B: Digital Identity Guidelines, Authentication and Lifecycle Management* (screening passwords against breach lists; use of MFA).
- SANS Institute. *Security Awareness Maturity Model* (moving from compliance-focused training to behaviour change).
- Verizon. *Data Breach Investigations Report* (annual; the human element features in a majority of breaches).
- Scenario facts: GRC206 Assignment Handout, "The scenario: Northbridge Logistics". All targets, sizes and tools above are my own proposals and assumptions.

Program calendar: 12 months at a glance

Month	Key activities	Audiences	Owners	Measurement and review
Pre-launch (6 weeks)	Capture baseline; unannounced baseline simulation; baseline survey; confirm sponsor and no-blame statement; recruit champions	All	HoIS, SAC, ITOM	Baseline for M1 to M6
1	Launch with COO message; Report button and hotline live; essentials module begins; leader briefing	All; leaders	SAC, ITOM, HR/L	M1 starts; first reports tracked
2	Finance fraud workshop and call-back job aid; warehouse toolbox talk 1 (passwords, shared handhelds); Simulation 1	Finance; warehouse; office	FD, SAC, OPS	M2 and M4 first reading
3 ★	Password manager and MFA rollout wave 1; service desk role play; Review 1	Head office; IT/HR; review group	ITOM, SAC, HoIS	M1 to M6 vs baseline; actions logged
4	Micro-module on phishing and impersonation; remote sales virtual session; Simulation 2	Office; remote sales	SAC	M2, M3
5	Rollout wave 2 (supervisors, sales); toolbox talk 2 (text and QR scams); learner pulse and focus groups	Sales; warehouse	ITOM, OPS, SAC	M5; feedback themes
6 ★	Finance drill; Simulation 3; “Great Catch” award launch; Review 2 with sponsor	Finance; office; all	FD, SAC, HoIS	O1 and O3 midpoint check; leadership briefing
7	Content refresh from Review 2 actions; text and QR simulation for warehouse sample	Warehouse	SAC, OPS	M2 (warehouse), M1
8	Micro-module on customer-data handling; remote sales session; Simulation 4	Office; sales; DPO input	SAC, DPO	M2, M3, M6
9 ★	Final MFA and password-manager push; service desk role play 2; Review 3	IT/HR; all; review group	ITOM, SAC, HoIS	O2 deadline check; M1 to M6
10	Finance drill and procedure refresh; toolbox talk 3 (visitors, tailgating); Simulation 5	Finance; warehouse; office	FD, OPS, SAC	M2, M4
11	Learner feedback round and focus groups; recognition celebration; draft year-two plan	All; champions	SAC, HR/L	Feedback analysis; M1
12 ★	Simulation 6; year-end data pull; Review 4 with sponsor; year-two	Office; all; executives	HoIS, SAC	O1 to O3 final results; annual report to executives

	proposal and budget request			

The calendar is sized for roughly one part-time coordinator: about one major delivery activity per month and one simulation every six weeks, with other roles giving local support.

Short reflection

The hardest part was balancing ambition with the reality of a small team and a mostly warehouse-based workforce. It is tempting to prescribe a lot of content, but a calendar nobody can maintain would fail within months, so I limited the program to three risks and roughly one major activity a month. The biggest uncertainty is the baseline: Northbridge may have little reliable history, so my targets are planning choices that I would adjust after the first quarter. A second trade-off was how to read incident numbers. Better reporting could make them rise at first, so I separated report volume from incidents that caused harm. I also chose to prioritise safer behaviour and no-blame reporting over simulation click rates, accepting that this is harder to measure but more honest about what protects the business.